

A Two-Signature Complete Pre-Signature DRBG State Rollback Attack on Qing Luan: Equivalent Signing-Witness Recovery and Fresh-Message Forgery Against the Claimed State-Reuse Robustness

Martin Feussner
Selmer Center, University of Bergen
martin.feussner@uib.no

1 October 2026

Provenance and review status. The attack, derivation, implementation, experiments, and initial manuscript were produced by OpenAI Codex using Daybreak Blue at Ultra reasoning effort during an AI-run audit of NGCC signature candidates. A separately instructed hostile-review agent rebuilt the extraction and forgery, tried to disprove the claim, and accepted only the conditional complete pre-signature DRBG state rollback result stated below. At the date above, no human cryptanalyst has independently verified the argument, implementation, measurements, or novelty assessment. This report is a preliminary disclosure for human review and reproduction.

Abstract

Qing Luan is a code-based Fiat–Shamir signature derived from the CROSS R-SDP protocol. Its specification separately considers what is effectively complete pre-signature DRBG state rollback to the same state immediately before both signing calls on different messages. It observes that the per-round seeds repeat while the Fiat–Shamir challenges change, but nevertheless claims strong robustness under temporary state reuse.

We show that this exact condition yields a practical two-signature witness recovery. Suppose one key signs two distinct messages after complete pre-signature DRBG state rollback to the same state immediately before both signing calls, so both calls repeat the hidden root seed and the public salt. Repetition of either value alone is insufficient. If the fixed-weight second challenges differ at a round i , one signature’s type-1 opening serializes Seed_i , from which η'_i is publicly derived, while the other signature’s type-0 opening serializes

$$v_i = \eta - \eta'_i \pmod{7}.$$

Thus $\eta = \eta'_i + v_i \pmod{7}$ is recovered directly. Because both second challenges have the same weight, any unequal pair contains such a cross-branch round. If the second challenges are identical, a separate type-0/type-0 fallback subtracts two affine responses with unequal first challenges. The recovered exponent vector satisfies the public R-SDP relation. It is an equivalent signing witness: it need not recover the original secret seed, but it permits ordinary signatures on arbitrary fresh messages.

A public-input extractor and witness-only signer reproduced the attack at all four submitted levels. The affine fallback’s main PDF-aligned hostile-review runs succeeded on 32/32, 8/8, 4/4, and 4/4 independent keys at 128, 256, 384, and 512 bits. The combined extractor exercised the simpler cross-branch route at every level under both PDF-aligned and untouched-source semantics. A second DRBG implementation also reproduced the affine route. Fresh-state and same-message pairs rejected extraction; all corrupted-response,

wrong-key, wrong-message, and forgery-binding controls behaved as required. For the timed affine runs, mean public extraction time, including verification of both source signatures, was between 0.010 and 0.313 CPU seconds and peak memory remained below 5 MiB.

This result is a conditional robustness failure under the complete pre-signature DRBG state rollback condition stated above. It does not break ordinary EUF-CMA signing with fresh independent randomness. Its design significance follows from Qing Luan’s explicit robustness statements for essentially this state-reuse condition. If those statements are withdrawn, the mechanism is instead a conditional fault/caller-misuse attack. Generic Fiat–Shamir nonce-reuse extraction is well known; the contribution here is limited to Qing Luan’s exact cross-branch seed/correction mechanism, its same-branch affine fallback, the transport to a complete R-SDP signing witness, and the resulting contradiction of the submission’s explicit robustness claim.

1 Introduction

Qing Luan supplies four code-based signature parameter sets built from the restricted syndrome decoding problem over $\mathbb{F}_{127}$ and the CROSS R-SDP identification protocol [1, 2]. It executes many parallel rounds, commits to secret-independent masks, derives two Fiat–Shamir challenges, and opens each round in one of two forms. The construction uses an SM3-based deterministic random-bit generator to sample a per-signature root and salt.

Randomness reuse is a standard special-soundness hazard for Fiat–Shamir signatures. Hedged derivations bind signing randomness to both the secret key and message precisely because a stateful generator can be reset, cloned, or restored from a virtual-machine snapshot [3]. Qing Luan’s supporting analysis recognizes the relevant event. Section 3.3.4 describes what is effectively complete pre-signature DRBG state rollback to the same state immediately before both signing calls on different messages: the round seeds repeat while the challenges differ. It then calls the construction strongly robust under temporary DRBG state reuse; Section 3.3.6 again says that the state-reuse mechanism is robust.

The repeated round seed is enough to expose the witness. The most direct route uses different second-challenge branches at one round: the type-1 opening supplies the round seed and hence η'_i , while the type-0 opening supplies $v_i = \eta - \eta'_i$. Adding them gives the long-term exponent vector. If the second challenges happen to be identical, two type-0 affine responses with different first challenges provide an independent fallback. The resulting witness is publicly checkable and can drive the ordinary prover on any new message.

Our contributions are as follows.

1. We give exact public extraction equations for two distinct-message signatures produced after complete pre-signature DRBG state rollback to the same state immediately before both signing calls, which repeats both the hidden root and public salt.
2. We show that one cross-branch round recovers an equivalent R-SDP signing witness. We retain an affine type-0/type-0 extractor as a fallback when the second challenge repeats.
3. We calculate ideal-model failure probabilities and keep those models, including their digest-collision limits, separate from concrete serialized-transcript experiments.
4. We implement a public-input extractor and a signer that receives only the recovered witness. Fresh-message forgeries pass the ordinary verifier at all four security levels.
5. We repair the submitted code to the PDF’s independent indexed-leaf and one-based domain rules before the main tests, and use untouched source only as corroboration.
6. We delimit the claim as a failure of the explicit robustness statements for the complete pre-signature DRBG state rollback condition stated above. We make no ordinary fresh-randomness EUF-CMA claim.

The generic lesson that repeated Fiat–Shamir randomness may expose a witness is not new. Qing Luan’s own special-soundness discussion describes extraction from complementary openings. The candidate-specific point is that the submission identifies essentially the same complete pre-signature DRBG state rollback condition and still asserts robustness; its serialized seed and correction make complete witness recovery immediate.

2 Qing Luan

2.1 Public relation and keys

All arithmetic in the protocol is over $\mathbb{F}_p$ with

$$p = 127, \quad z = 7, \quad g = 2, \quad E = \langle g \rangle = \{1, 2, 4, 8, 16, 32, 64\} \subset \mathbb{F}_p^*.$$

For code length n and dimension k , set $r = n - k$ and expand the public seed into

$$H = [V \mid I_r] \in \mathbb{F}_p^{r \times n}.$$

Key generation samples $\eta \in \mathbb{Z}_7^n$, sets

$$e = g^\eta \in E^n, \quad s = eH^\top, \quad (1)$$

and publishes a seed for H together with s . The submitted secret key is a seed that regenerates η .

For signing, the seed is only a compact representation. Any vector $\tilde{\eta} \in \mathbb{Z}_7^n$ satisfying

$$g^{\tilde{\eta}} H^\top = s \quad (2)$$

is an equivalent signing witness. It allows the holder to execute every secret-dependent signing equation, even if it does not invert the original secret-seed expansion.

The relevant parameters are shown in Table 1. The second challenge has fixed Hamming weight w among t rounds; therefore exactly $a = t - w$ rounds use the type-0 response that is central to the attack.

Table 1: Qing Luan parameters and serialized sizes.

profile	(n, k, r)	t	w	$a = t - w$	$ \mathbf{pk} $	$ \mathbf{sk} $	$ \sigma $
128	(127, 76, 51)	256	212	44	77	32	18,720
256	(251, 150, 101)	512	424	88	153	64	74,248
384	(370, 221, 149)	763	631	132	227	96	164,940
512	(491, 293, 198)	1018	842	176	302	128	292,816

2.2 Per-round state

Each signing call draws a hidden root, denoted **Seed**, and a public salt. The written specification derives an independently indexed **Seed** _{i} for every round. Expanding it produces

$$\eta'_i \in \mathbb{Z}_7^n, \quad u'_i \in \mathbb{F}_p^n.$$

The signer forms

$$v_i = \eta - \eta'_i \pmod{7}, \quad (3)$$

$$e'_i = g^{\eta'_i}, \quad (4)$$

$$u_i = g^{v_i} \odot u'_i, \quad s'_i = u_i H^\top. \quad (5)$$

Here $\odot$ denotes coordinatewise multiplication. Commitments bind s'_i , v_i , the round seed, the salt, and their domains.

After hashing the message and commitments, the first Fiat–Shamir challenge contains a nonzero scalar

$$\beta_i \in \mathbb{F}_p^*.$$

The signer computes

$$y_i = u'_i + \beta_i e'_i. \quad (6)$$

The fixed-weight second challenge selects one of two openings. A type-1 opening discloses the round seed. A type-0 opening serializes y_i , v_i , and the complementary commitment. From those public values the verifier reconstructs

$$(g^{v_i} \odot y_i) H^\top - \beta_i s = s'_i, \quad (7)$$

because

$$g^{v_i} \odot y_i = g^{v_i} \odot u'_i + \beta_i g^{v_i + \eta'_i} = u_i + \beta_i e.$$

2.3 The stated complete pre-signature DRBG state rollback scenario

The signing API obtains the root and salt from two sequential calls to its DRBG. Complete pre-signature DRBG state rollback to the same state immediately before both signing calls repeats both draws. For two different messages, the repeated root and salt reproduce every Seed_i , η'_i , u'_i , v_i , and round commitment. Message binding changes the Fiat–Shamir challenges with overwhelming probability.

This is the scenario described in Section 3.3.4 of the submission, using its “reset” terminology: round seeds repeat while challenges differ. The specification’s conclusion of “strong robustness under DRBG temporary-state reuse” overlooks that complete pre-signature DRBG state rollback reproduces both draws. The attack below does not arise when the DRBG advances normally and supplies independent signing state.

3 The rollback extractor

3.1 Cross-branch extraction

Let σ and σ' be valid signatures on distinct messages under one public key. Assume complete pre-signature DRBG state rollback to the same state immediately before both signing calls, so both use the same hidden root and public salt. Let B and B' be the respective sets of type-1 positions. Both sets have cardinality w .

Suppose first that $B \neq B'$. There is an index in their symmetric difference; without loss of generality, choose $i \in B \setminus B'$. The type-1 opening in σ serializes Seed_i . Applying the public round expansion to that seed, the repeated salt, and the round domain gives η'_i . The type-0 opening at the same index in σ' serializes v'_i . Complete pre-signature DRBG state rollback makes the hidden round state identical, so

$$\hat{\eta} = \eta'_i + v'_i = \eta \pmod{7}. \quad (8)$$

One cross-branch position therefore recovers every coordinate of the long-term exponent witness. No first-challenge difference or discrete logarithm is needed.

3.2 Same-branch affine fallback

If $B = B'$, every type-0 position is shared. Consider one such round i . Repetition of the round state gives

$$\begin{aligned} y_i &= u'_i + \beta_i e'_i, \\ y'_i &= u'_i + \beta'_i e'_i. \end{aligned} \tag{9}$$

If $\beta_i \neq \beta'_i$, coordinatewise subtraction and division in $\mathbb{F}_p$ yield

$$\tilde{e}'_i = (y_i - y'_i)(\beta_i - \beta'_i)^{-1}. \tag{10}$$

The serialized correction then gives

$$\hat{e} = g^{v_i} \odot \tilde{e}'_i. \tag{11}$$

Theorem 1 (Conditional witness recovery). *Suppose two honestly generated Qing Luan signatures under the same key sign distinct messages after complete pre-signature DRBG state rollback to the same state immediately before both signing calls, repeating both the hidden root and public salt. If their second-challenge vectors differ, Equation (8) recovers the long-term exponent vector η . If those vectors are identical but some type-0 round has $\beta_i \neq \beta'_i$, Equations (10) and (11) recover the long-term restricted error e , whose coordinatewise discrete logarithms give η . In either case, η is an equivalent signing witness.*

Repetition of either the hidden root or public salt alone does not satisfy the theorem's rollback hypothesis and is insufficient for this extraction.

Proof. For a cross-branch round, the type-1 seed expands to the same η'_i used to compute the other signature's type-0 correction. Equation (3) then proves Equation (8). For the affine fallback, complete pre-signature DRBG state rollback repeats η'_i and u'_i . Subtracting Equation (9) cancels u'_i and gives $(\beta_i - \beta'_i)g^{\eta'_i}$, so $\tilde{e}'_i = g^{\eta'_i}$. By Equation (3),

$$\hat{e} = g^{\eta - \eta'_i} \odot g^{\eta'_i} = g^\eta = e.$$

Every coordinate lies in the seven-element group E , so its discrete logarithm to base g is found by a seven-entry table. The resulting exponent vector satisfies Equation (2). $\square$

The public extractor first verifies both input signatures and derives both challenge vectors. It tries every cross-branch position using the serialized type-1 seed and opposite type-0 correction; if necessary, it tries shared type-0 positions with unequal first challenges. It accepts a candidate only if every exponent is in $\mathbb{Z}_7$, the corresponding restricted vector satisfies $eH^\top = s$, and every other usable position recovers that same vector. Its interface is

$$(\text{pk}, M, \sigma, M', \sigma') \mapsto \eta \text{ or failure.}$$

It receives no secret key, secret-seed expansion, DRBG state, expected witness, hidden root, unexposed round seed, or signer instrumentation. Its only round seed input is the one already serialized by a public type-1 opening.

3.3 Fresh-message forgery

Given the recovered η , the adversary can choose fresh signing randomness and compute the signing state using Equations (3)–(6). It can then serialize an ordinary proof for any message. The secret seed is unnecessary. The accompanying witness-only signer takes (pk, M, η) and produces a conventional Qing Luan signature. Thus the result is equivalent signing-witness recovery followed by fresh-message forgery, not merely a distinguisher or transcript correlation.

3.4 Ideal-model success probability

Let $B, B' \subseteq \{1, \dots, t\}$ be the type-1 positions, with $|B| = |B'| = w$. In the ideal model where both fixed-weight challenges are independently uniform, cross-branch extraction fails exactly when $B = B'$:

$$P_{\text{cross-fail}}^{\text{ideal}} = \binom{t}{w}^{-1}. \quad (12)$$

If that collision occurs, all $a = t - w$ type-0 positions are shared. An additional abstraction that treats their first-challenge scalars as independent uniform elements of $\mathbb{F}_p^*$ makes the affine fallback fail with conditional probability 126^{-a} . Ignoring the finite digest layers would therefore give the product $(\binom{t}{w} 126^a)^{-1}$.

Table 2: Cross-branch failure in the uniform fixed-weight ideal model. These are not exact probabilities for conditioned serialized signatures.

profile	$a = t - w$	$-\log_2 P_{\text{cross-fail}}^{\text{ideal}}$
128	44	165.543619
256	88	334.510906
384	132	502.320455
512	176	671.306477

Equation (12) is exact only for its stated uniform fixed-weight model. A layered ideal-hash calculation also shows why the abstract product must not be reported as the concrete failure probability. Let $h = 2\lambda$, $q = 2^{-h}$, $D = \binom{t}{w}$, and $d = q + (1 - q)q$. Here d models a collision in the message digest or, otherwise, in `digest_chall1`; either event repeats the entire challenge cascade. Conditional on avoiding it, equality of the second challenge has modeled probability $c = q + (1 - q)/D$, accounting first for a collision in its h -bit digest and then for the fixed-weight sampler. The layered model gives

$$P_{\text{cross-fail}} = d + (1 - d)c, \quad P_{\text{combined-fail}} = d + (1 - d)126^{-a}c.$$

The combined failure is consequently dominated by about $2^{-(2\lambda-1)}$, not by the much smaller digest-free product. These remain idealized calculations; concrete challenges are hashes of conditioned serialized transcripts. We report real-signer results separately.

4 Specification alignment and implementation

4.1 Main PDF-aligned experiment

The main experiment starts from fresh copies of the submitted source and makes two semantic repairs required by the PDF:

1. derive each round leaf independently as an indexed expansion, rather than slicing one unindexed XOF stream;
2. use the PDF’s one-based round number in every $i + c$ domain, rather than the source’s zero-based value.

The bundled protocol reference’s key-expansion constants are retained where the main PDF abbreviates them. The complete patch accompanies the reproducer. The attack is then tested against the repaired signer and verifier, so neither submitted deviation is an attack premise.

For each trial, the producer generates a fresh key and distinct messages, induces complete pre-signature DRBG state rollback to the same state immediately before both signing calls,

and outputs two valid serialized signatures. The extractor receives only the public tuple. A separate replay check confirms that the two sequential DRBG outputs—the hidden root and serialized salt—repeat exactly, but does not pass them to the extractor.

The witness-only signer receives the recovered η and an unqueried message. The ordinary verifier checks the resulting signature. AddressSanitizer and UndefinedBehaviorSanitizer runs cover the PDF-aligned 128- and 512-bit paths.

4.2 Untouched-source corroboration

The same independent harness is also linked to byte-for-byte untouched submitted core copies. This corroboration shows that the effect was not introduced by the conformance patch. It is not used to replace the normative PDF-aligned result. A second experiment uses a standalone implementation of the documented DRBG, which rules out an unrelated rotate operation in the submitted API generator as the cause.

5 Results

Table 3 gives the independently rebuilt affine hostile-review runs and the combined cross-branch reproductions. Every numerator is a complete sequence of two valid signatures produced after complete pre-signature DRBG state rollback to the same state immediately before both signing calls, public witness recovery, an unqueried-message signature using only that witness, ordinary-verifier acceptance, and all negative controls.

Table 3: End-to-end recovery and fresh-message forgery.

semantics and randomness backend	128	256	384	512
affine: PDF-aligned / submitted API DRBG	32/32	8/8	4/4	4/4
affine: PDF-aligned / standalone documented DRBG	4/4	4/4	2/2	2/2
affine: untouched submitted core / API DRBG	4/4	4/4	2/2	2/2
combined: PDF-aligned / documented DRBG	1/1	1/1	1/1	1/1
combined: untouched core / documented DRBG	1/1	1/1	1/1	1/1

In the main PDF-aligned/API affine runs, the observed minimum, mean, and maximum type-0 overlaps were

$$3/6.844/12, \quad 12/16.375/21, \quad 18/22.250/28, \quad 22/33.000/49$$

from 128 through 512. Occasional overlaps with equal β were skipped; all remaining candidate rounds recovered the same witness.

For those affine runs, mean extraction CPU time, including two ordinary signature verifications, was 0.010, 0.052, 0.148, and 0.313 seconds. Peak resident memory for complete batches stayed below 5 MiB. Public algebra costs $O(tn + rk)$ small-field operations and comparable storage. Online data is two signatures: 37,440, 148,496, 329,880, and 585,632 bytes at the four levels, plus the public key and messages.

Every trial required the following controls to pass:

- signatures generated from different advancing DRBG states verified, but extraction rejected;
- same-message complete pre-signature DRBG state rollback to the same state immediately before both signing calls produced identical signatures and no unequal first challenge, and the public attack interface rejected equal messages;
- a one-bit corruption in a serialized type-0 y_i made verification and extraction reject;

- a separately generated public key and an altered source message made verification and extraction reject;
- the valid fresh-message forgery failed when paired with a previously queried message.

6 Scope, prior work, and novelty

The attack requires all of the following:

1. one long-term Qing Luan key;
2. two distinct messages;
3. complete pre-signature DRBG state rollback to the same state immediately before both signing calls, repeating both the hidden root and public salt;
4. either unequal second challenges, which guarantee a cross-branch round, or—for the affine fallback after an identical second challenge—one shared type-0 round with unequal first challenges.

It does not apply to an ordinary signing oracle whose DRBG state advances and supplies fresh independent values. Repetition of either the hidden root or public salt alone is insufficient.

Randomness-reuse extraction in Fiat–Shamir signatures is established prior art. Aranha, Orlandi, Takahashi, and Zaverucha analyze fault resilience and hedged derivations that bind the secret key, message, and external randomness [3]. ZKFault studies fault attacks on compressed zero-knowledge signatures including CROSS through a different fault surface [4]. The Qing Luan specification itself describes special-soundness extraction from complementary openings and predicts repeated round seeds under what is effectively the complete pre-signature DRBG state rollback scenario.

Accordingly, we claim neither the generic nonce-reuse idea nor a new special-soundness principle. The narrow contribution is the Qing-Luan-specific chain

$$(\text{Seed}_i, v'_i) \mapsto (\eta'_i, v'_i) \mapsto \eta,$$

together with the same-branch affine fallback, its public-input end-to-end validation at every parameter level, and the fact that it directly contradicts the submission’s explicit robustness conclusion for that rollback scenario. A final best-effort check at 16:28 UTC on 1 October 2026 found that the Qing Luan page on ngcc.dev still listed only `sign-20-1`, an unrelated Medium proof gap in the 128-bit parameter’s quantum accounting [5]. No public report applying this exact Qing Luan transcript pair to complete pre-signature DRBG state rollback was found; that negative search is not a definitive novelty proof.

If the specification withdraws its robustness statements and treats correct fresh DRBG evolution as an unconditional environmental requirement, the result should be classified as a conditional fault/caller-misuse attack. It should still inform implementations that support VM snapshots, deterministic test replay, external DRBG injection, or recoverable persistent state.

7 Repair

A robust repair should hedge the per-signature root with both secret and message-bound material. For example, derive separate root and salt subkeys from a construction of the form

$$\text{PRF}(\text{domain} \parallel \text{sk} \parallel \text{Hash}(\text{pk}) \parallel \text{Hash}(M) \parallel \text{external_randomness}).$$

Binding the public-key and message digests into every indexed round-seed derivation prevents a repeated external-randomness value from reproducing the same masks across different messages.

Root and salt derivations should use separate domain labels. A persistent anti-rollback counter may provide defense in depth, but the cryptographic derivation should remain safe if that state repeats.

The exact repair requires a revised byte-level specification and proof. Alternatively, the current text must remove the reset/state-reuse robustness claims and state that complete pre-signature DRBG state rollback to the same state immediately before both signing calls on different messages exposes the signing witness.

8 Conclusion

Two Qing Luan signatures created after complete pre-signature DRBG state rollback to the same state immediately before both signing calls, which repeats both the hidden root and public salt, expose the long-term exponent witness through one complementary opening; a repeated type-0 round supplies an independent affine fallback. The recovered exponent vector is an equivalent signing witness and produces ordinary fresh-message signatures. Repetition of either the hidden root or public salt alone is insufficient. The attack is polynomial, has near-unit success in the stated ideal challenge model, and reproduces at every submitted security level.

The result has a strict boundary: it is not an ordinary fresh-randomness EUF-CMA break. Its design significance follows from Qing Luan’s explicit robustness claim for essentially this condition: complete pre-signature DRBG state rollback to the same state immediately before both signing calls. That condition creates the complementary public openings. If the claim is withdrawn, the result should instead be classified as a conditional fault/caller-misuse attack.

Acknowledgements

The computations were performed on the Norwegian Research and Education Cloud (NREC), using resources provided by the University of Bergen and the University of Oslo.

Artifact availability

The accompanying reproducer contains the PDF-alignment patch, independent public-input extractor, witness-only signer, untouched-source corroboration, negative controls, exact ideal-probability calculation, and one-command build and run instructions. It does not require either source secret key as an extractor input.

References

- [1] Wu Guangfu, Liu Lei, Wu Rui, Liu Lulu, and Li Kangjun, *Qingluan Post-Quantum Digital Signature Algorithm Text*, NGCC submission specification, 2026.
- [2] M. Baldi, M. Battaglioni, F. Chiaraluce, A.-L. Horlemann, E. Persichetti, P. Santini, and V. Weger, “A new path to code-based signatures via identification schemes with restricted errors,” *Advances in Mathematics of Communications*, vol. 19, no. 5, pp. 1360–1381, 2025.
- [3] D. F. Aranha, C. Orlandi, A. Takahashi, and G. Zaverucha, “Security of hedged Fiat–Shamir signatures under fault attacks,” in *Advances in Cryptology—EUROCRYPT 2020*; full version, IACR Cryptology ePrint Archive, Report 2019/956, 2021.
- [4] P. Mondal, S. Adhikary, S. Kundu, and A. Karmakar, “ZKFault: Fault attack analysis on zero-knowledge based post-quantum digital signature schemes,” in *Advances in Cryptology—*

ASIACRYPT 2024, pp. 132–167; IACR Cryptology ePrint Archive, Report 2024/1422, 2024.

- [5] NGCC Security Reports, *Qing Luan (sign-20)*, <https://ngcc.dev/reports/sign-20.html>, accessed 1 October 2026.